Executive Summary

A SOC 2 audit simulation was conducted for NovaPay Fintech Ltd to evaluate the design and operating effectiveness of controls aligned with the Trust Services Criteria established by the American Institute of Certified Public Accountants.

The audit identified several control deficiencies, particularly in access management, monitoring, incident response and privacy governance. While certain controls such as data encryption and system monitoring are in place, critical gaps limit the overall effectiveness of the control environment.

This report outlines key findings and provides recommendations to strengthen NovaPay's readiness for a SOC 2 Type II audit.

Introduction

SOC 2 is a widely recognized framework used to assess an organization's controls related to security, availability, processing integrity, confidentiality and privacy.

This audit simulation evaluates NovaPay's control environment with a focus on the Security Trust Services Criteria and determines whether controls are effectively designed and operating as intended.

Scope

This audit covers key controls related to access management, system monitoring, data protection and incident response across NovaPay's systems and processes.

Audit Methodology

The audit was conducted using a structured approach, including:

- Review of policies and procedures
- Inspection of system configurations
- Evaluation of control design
- Testing of control effectiveness
- Review of supporting evidence

Control Testing Results

The results of control testing indicate that several controls are not operating effectively.

- Controls related to access management (e.g., MFA, access reviews) were found to be ineffective
- Monitoring controls were partially implemented but lacked active oversight
- Incident response controls were not established
- Data protection controls were generally effective

Findings

The audit identified the following key issues:

- Lack of Multi-Factor Authentication (MFA)
- Absence of periodic access reviews
- Lack of centralized logging and monitoring
- No formal incident response plan
- Absence of a defined privacy policy

Recommendations

To improve control effectiveness and SOC 2 readiness, NovaPay should:

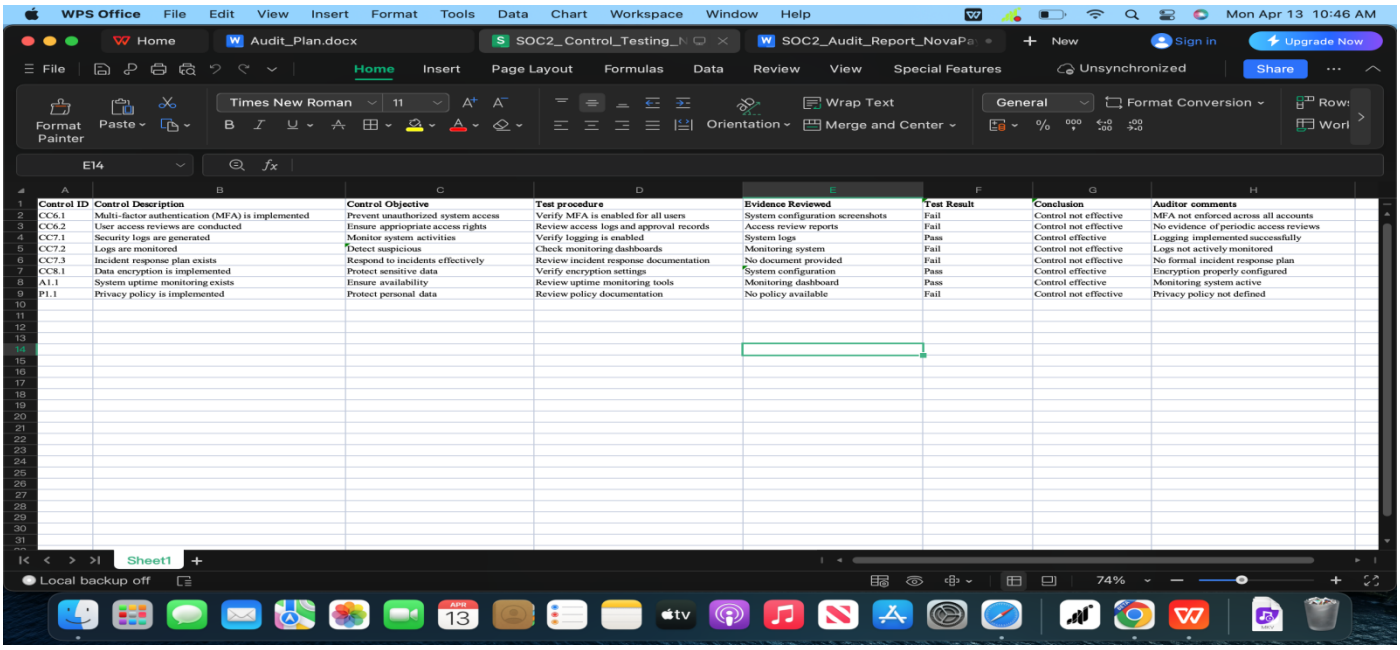
- Implement Multi-Factor Authentication (MFA) across all systems
- Establish periodic access review processes
- Deploy centralized logging and monitoring tools
- Develop and implement an incident response plan
- Define and enforce a privacy policy

Conclusion

Based on the procedures performed, the control environment at NovaPay Fintech Ltd is not currently operating at a level sufficient to meet SOC 2 Type II requirements.

Several critical controls are either not implemented or not operating effectively. Remediation of identified gaps is required before the organization can successfully undergo a SOC 2 audit.

Figure 1: Control testing summary



Control ID	Control Description	Control Objective	Test procedure	Evidence Reviewed	Test Result	Conclusion	Auditor comments
CC6.1	Multi-factor authentication (MFA) is implemented	Prevent unauthorized system access	Verify MFA is enabled for all users	System configuration screenshots	Fail	Control not effective	MFA not enforced across all accounts
CC6.2	User access reviews are conducted	Ensure appriopriate access rights	Review access logs and approval records	Access review reports	Fail	Control not effective	No evidence of periodic access reviews
CC7.1	Security logs are generated	Monitor system activities	Verify logging is enabled	System logs	Pass	Control effective	Logging implemented successfully
CC7.2	Logs are monitored	Detect suspicious	Check monitoring dashboards	Monitoring system	Fail	Control not effective	Logs not actively monitored
CC7.3	Incident response plan exists	Respond to incidents effectively	Review incident response documentation	No document provided	Fail	Control not effective	No formal incident response plan
CC8.1	Data encryption is implemented	Protect sensitive data	Verify encryption settings	System configuration	Pass	Control effective	Encryption properly configured
A1.1	System uptime monitoring exists	Ensure availability	Review uptime monitoring tools	Monitoring dashboard	Pass	Control effective	Monitoring system active
P1.1	Privacy policy is implemented	Protect personal data	Review policy documentation	No policy available	Fail	Control not effective	Privacy policy not defined